IT Governance Case

Melvin Viado: 100899671

Cybersecurity, Durham College

MGMT1216: Security Auditing and Governance

Jerrard Gaetner

March 12, 2026

Assignment Questions

Question 7

Introduction

The Balanced Scorecard in the CPA booklet (Baker, 2012) is an approach that organizations use to "develop goals and monitor performance" that looks beyond financial measures and differentiates from a comprehensive view from Apex Precision Manufacturing's (APM) organizational goals and objectives. APM currently tracks operational equipment efficiency (OEE), scrap rates, on-time delivery, and customer profitability. While APM have adequate metrics on operational excellence from OEE and scrap rates, customer orientation from on-time delivery, and corporate contribution from customer profitability, there are no metrics on future orientation. APM fails to build the foundation for future delivery and continuous learning and growth.

Metric Adequacy

OEE and scrap rates are purely operational metrics that have high adequacy to the operational excellence since it is a direct indicator of operational service performance. OEE refers to the measure of how an equipment is effectively used accounting for availability, performance, and quality, while scrap rates measure the percentage of discarded materials. It is key to keep in mind that these metrics do not reflect the value of the information assets and only reflect the equipment. On-Time Delivery provides moderate adequacy to customer orientation as it is an indicator of how well their delivery service is as a service provider. Customer profitability has high adequacy to corporate contribution as it links to financial value and APM's ability to deliver value. To reiterate, no metrics on future orientation are found.

Key Performance Indicators

The following are two additional key performance indicators (KPIs) for each of the scorecard perspectives that would give APM's board a more complete view of information-asset performance and value. For Corporate Contribution, IT Return on Investment and IT Spending would allow the board to identify financial returns generated from specific assets and to see APM's financial discipline and efficiency in resource allocation. For Customer Orientation, Net Promoter Score and Service Level Agreement Compliance are KPIs that show how likely a customer would recommend APM based on service experience and the percent that APM meets their service targets. For Operational Excellence, System Uptime and Incidence Response Time are KPIs that show how operational equipment are and how quick threats are identified and mitigated. For Future Orientation, Staff Training Hours and New Product Revenue Percentage are KPIs that measures the training of workers on new technologies and how well innovation translates to business.

Conclusion

The board needs to their organizational views from metrics on historical performance and internal efficiency to strategic growth and digital readiness as suggested in the model of the CPA booklet. Since APM is primarily in "Factory Mode", innovations can "reduce costs and improve service efficiency and reliability" (Baker, 2012, p. 21). By adopting these new metrics, APM will move from monitoring costs to managing assets while providing a view on how innovative technology supports long-term competitive advantage.

Question 1

Introduction

APM should be positioned in the Strategic Mode quadrant because manufacturing in the aerospace industry is tied to technical compliance and efficiency with AI. APM shows that they use aggregated data from their Azure data warehouse to track metrics such as OEE and customer profitability, implying that they are aiming for major cost reductions and service transformations. Although it seems like APM only has high operational independence, their involvement in IT, AI, and technical compliance shows that APM requires IT development.

Internal Analysis

On the IT Strategic Impact Grid, Strategic Mode lies toward the high need for reliable information technology. To begin, APM runs its core process through SAP S/4HANA with Siemens MES to govern CNC machining operations across 38 machines. Following that, APM has automated purchase orders and scheduling where a system failure would halt the supply chain and automation. Lastly, APM uses Manhattan Associates WMS coordinates for inbound and outbound shipments from electronic data interchange transactions with customers and carriers. These operational dependencies show that APM heavily relies on maintenance and management of many machines, just-in-time automation, and reliance on logistics.

APM is also proven to require reliable IT from the presence of it's "predictive maintenance application build" to "forecast spindle bearing failures" and "reduce unplanned downtime by an estimated 30%" (APM Case, p. 2). Most of APM's systems work is maintenance and the business will experience an immediate loss if systems fail for a long period of time.

External Analysis

The following shows the need for new information technology within APM. Primarily, failure in information asset management could result in loss of contracts worth multiple millions as "Tier-1 aerospace OEMs contractually require demonstrated compliance with NIST SP 800-171 for handling unclassified information (CUI)". (APM Case, p. 1). APM also relies on data for strategic competitive decisions because they track customer profitability and OEE using their business intelligence environment using Power BI with an Azure Synapse Analytics data warehouse. These factors suggest security measures and efficiency must evolve within APM.

Board Governance Implications

In Strategic Mode, the board must make IT and cybersecurity risk an important issue to be regularly addressed in board meetings where currently, the board only receives updates for capital expenditures. The board should also acquire a director with technology expertise to IT contractual obligations as non of the board members currently have formal IT or cybersecurity qualifications. The board should also enforce a formal business continuity plan and test the effectiveness of the long-untested disaster recover plan. Lastly, the concerns about remote-access grants not being fully revoked since the pandemic should also be addressed to meet NIST SP 800-171 compliance.

Question 2

Introduction

APM's current board-level governance of information assets has many deficiencies that show that the leadership and organizational structure could be greatly improved. In the areas of presence of technological competency, IT security, and risk management, APM's strategies and objectives can be better met through the implementation of suggestions in the following paragraph. Following this, the recommended governance structure of APM that would satisfy the COBIT 2019 principle of stakeholder transparency would be the formalization of information flows.

Current Board-Level Governance Evaluation

APM's governance is well suited for a traditional manufacturing company, but not for a highly technological aerospace manufacturing company. To start, we can mention that there are no board members with IT or cybersecurity qualifications to oversee demonstrated compliance with NIST SP 800-171.Following that, the board is only updated from IT when capital expenditure approval is required or after a significant incident. This is a contradiction to COBIT 2019 principle of continuous oversight as organizations are encouraged to "continuously assess and adapt their governance practices to keep pace with technological advancements and changing business process needs" (Cobit Guide).

We move our focus to the disaster recovery plan that has not been tested in 18 months and lack of a formal business continuity plan. In this case, APM lacks a proper risk management system where the business would incur a great loss if an incident were to happen. An event such as this is not unlikely as APM has security vulnerabilities like their remote access exceptions. During the pandemic, the board has granted remote access that were not revoked post-pandemic which creates a vector of attack to operational technology.

Recommended Governance Structure

A governance structure that would create a proper flow of information from manufacturing plans to the board room would be highly recommended for APM's case. The presence of a section of the board focused more on information technology strategy, risk, and investment would solve problems such as ineffective IT risk management strategies. The recruitment of at least one main directory with cybersecurity or IT experience would also give APM a representative of IT and cybersecurity processes to other board members effectively. Most importantly, an audit team would be critical here to continually test NIST SP 800-171 compliance and follow contractual compliance.

We would ensure stakeholder transparency in APM's case by implementing executive dashboards that show APM's metrics from the Azure Synapse data warehouse. Additionally, it is recommended that the board ensures transparency in NIST compliant reporting on top of compliance demonstrations to protect APM's OEM customers. This ensures that data about the manufacturer are accurate and visible.

References

Cobit Guide: Principles, enablers & IT governance explained. Optro. (n.d.). https://optro.ai/blog/cobit

Durham College. (2026, March 12). APM Case.

NIST Special Publication 800 NIST SP 800-171r3. (n.d.). https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r3.pdf